

ANALISIS INSIDEN KEBOCORAN DATA PELANGGAN PADA PERUSAHAAN E-COMMERCE

Rivaldo 231011750218

Sebuah perusahaan e-commerce mengalami kebocoran data pelanggan setelah pihak yang tidak berwenang berhasil mengakses database menggunakan akun administrator dengan kata sandi yang lemah dan tanpa MFA. Data yang bocor meliputi nama pelanggan, nomor telepon, alamat, email, dan riwayat transaksi.

1. Jenis gangguan atau ancaman keamanan TI

- Terjadi insiden kebocoran data (data breach) dan akses tidak sah (unauthorized access). Penyerang berhasil memperoleh akses ke database pelanggan lalu menyebarkan informasi yang diperoleh ke forum internet.

2. Kelemahan atau celah keamanan

- Kata sandi administrator mudah ditebak, tidak diterapkan Multi-Factor Authentication (MFA), kemungkinan kurangnya pemantauan aktivitas akun, serta lemahnya pengelolaan kontrol akses.

3. Aspek CIA yang paling terdampak

- Aspek yang paling terdampak adalah Confidentiality (kerahasiaan) karena data pelanggan diakses dan disebarluaskan tanpa izin. Integrity tidak terbukti terganggu karena tidak ada informasi bahwa data diubah, sedangkan Availability tidak disebutkan mengalami gangguan layanan.

4. Risiko bagi pelanggan

- Pencurian identitas, penipuan melalui phishing, spam, penyalahgunaan data pribadi, kerugian finansial, serta hilangnya privasi.

5. Risiko bagi perusahaan

- Kehilangan kepercayaan pelanggan, kerusakan reputasi, sanksi hukum dan regulasi, potensi tuntutan hukum, penurunan pendapatan, serta biaya pemulihan insiden.

6. Strategi pencegahan

- Menerapkan MFA, kebijakan kata sandi kuat, enkripsi data, audit keamanan berkala, pelatihan kesadaran keamanan, monitoring dan logging, pembatasan hak akses berdasarkan prinsip least privilege, serta penggunaan sistem deteksi intrusi.

7. Langkah setelah insiden

- Mengisolasi sistem yang terdampak, mengganti kata sandi dan kredensial, melakukan investigasi forensik, memberi notifikasi kepada pelanggan dan pihak terkait, menutup celah keamanan, serta meningkatkan pengawasan keamanan.

8. Rencana mitigasi jangka pendek dan panjang

- Jangka pendek: reset seluruh password, aktifkan MFA, lakukan audit akun, monitoring aktivitas mencurigakan, dan pemulihan sistem. Jangka panjang: membangun kebijakan keamanan informasi, menerapkan framework keamanan, melakukan penetration testing rutin, meningkatkan pelatihan pegawai, dan memperkuat tata kelola keamanan data.